

INCIDENT INVESTIGATION REPORT

SOC332 — Fake Browser Update: Social Engineering to Malicious Execution

LetsDefend SOC Simulation | NIST SP 800-61 Aligned DFIR Case Study | Prepared for Portfolio Use

Ediz YURDAGÜL | edizyurdagul@hotmail.com

Alert / Scenario	SOC332 - Fake Browser Update (Social Engineering to Malicious Execution)
Classification	True Positive — Trojan / Fake Update
Threat Family	CosmicDuke / MiniDuke (APT29-associated indicators)
Severity	High
Status	Contained
Target Host	LetsDefend Host (EC2AMAZ-ILGVOIN\LetsDefend)
Incident Date	October 15, 2024

1. Executive Summary

On October 15, 2024, a user on the LetsDefend host received an email disguised as an urgent Chrome security update notice. The email pressured the recipient to download and run an attached file, chrome-updates.zip, to "install critical updates." The user complied, extracting and executing Chrome_updates.exe — a trojan masquerading as a legitimate browser updater (MITRE T1204.002, T1036).

Shortly after execution, the malicious process crashed, triggering Windows Error Reporting (WerFault.exe) and leaving behind a memory crash dump. Static and reputation analysis of the artifact recovered from this crash — identified internally as chrome.exe — confirmed it as a known malware family with strong indicators linking it to CosmicDuke/MiniDuke, a toolset historically associated with the APT29 threat actor.

Network traffic analysis found no evidence of a successful outbound connection to a command-and-control (C2) server, and no data exfiltration was observed. However, the absence of a completed C2 channel does not equal a clean host: the malware executed, the payload was confirmed malicious, and the file sat unquarantined on disk until analyst intervention. The host was isolated, the malicious artifacts were removed, persistence mechanisms were checked, and the affected user's credentials were reset.

Verdict: True Positive. The incident is classified as a contained compromise at the Execution phase, with no confirmed Command & Control or Exfiltration achieved.

2. Incident Details & Scope

Incident Date	October 15, 2024
Platform	LetsDefend SOC Simulation
Target Host / User	LetsDefend Host (EC2AMAZ-ILGVOIN\LetsDefend)
Initial Access Vector	Phishing email with malicious ZIP attachment (social engineering)

Malicious File	Chrome_updates.exe (delivered inside chrome-updates.zip)
Threat Classification	Trojan / Fake Browser Update
Threat Family	CosmicDuke / MiniDuke (65/69 VirusTotal detections)
Severity	High
Verdict	True Positive
Status	Contained — no confirmed C2 or data exfiltration

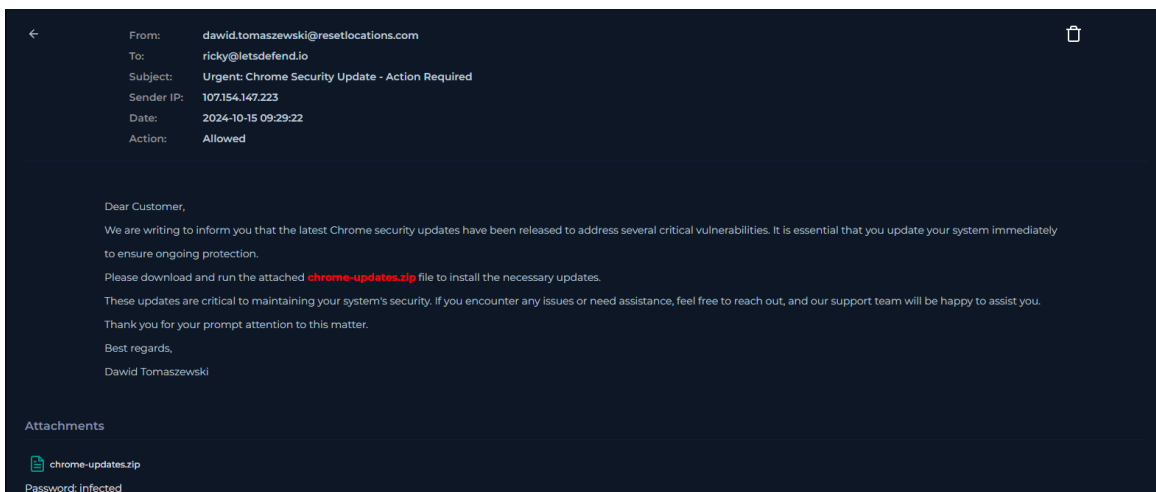
3. MITRE ATT&CK Mapping

Tactic	Technique ID	Name	Description
Initial Access / Execution	T1204.002	User Execution: Malicious File	User was socially engineered into downloading and manually executing Chrome_updates.exe, believing it was a legitimate Chrome security update
Defense Evasion	T1036	Masquerading	The malicious binary was named and presented as a Chrome updater to blend in with legitimate browser-update behavior and lower user suspicion
Execution / Defense Evasion	T1218	System Binary Proxy Execution (WerFault.exe)	The native Windows Error Reporting binary (WerFault.exe) was invoked when the malicious process crashed — see Section 4 for the distinction between this incidental invocation and deliberate LOLBin abuse

4. Technical Analysis & Timeline

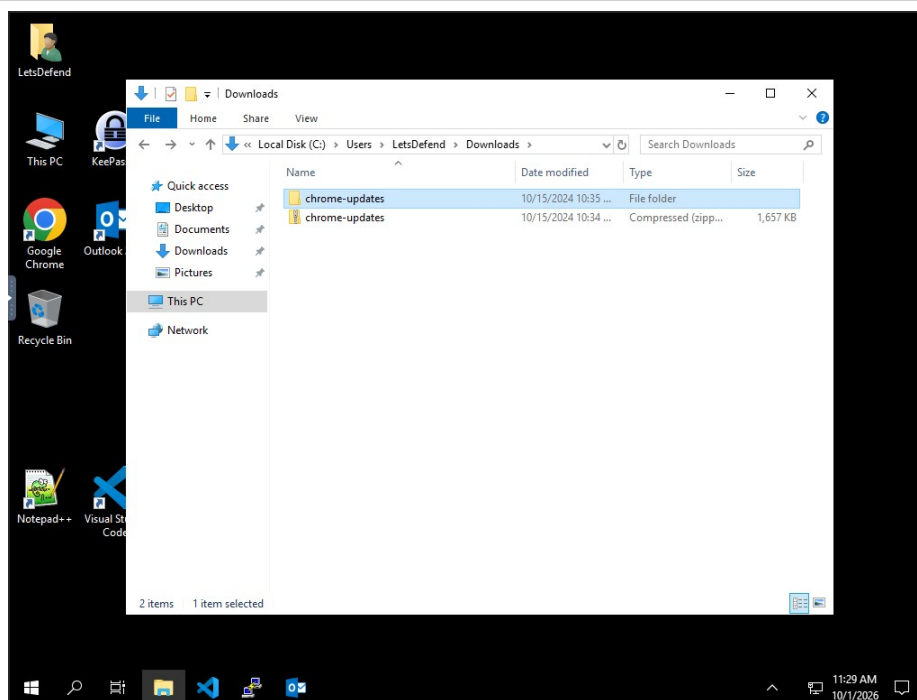
4.1 Initial Access & Execution

The attacker sent an email from dawid.tomaszewski@resetlocations.com to the target user, spoofing urgency around a "Chrome Security Update." The message instructed the recipient to download and run the attached chrome-updates.zip (password-protected with "infected" — a common technique to bypass email attachment scanning, since most mail gateways cannot inspect encrypted archive contents).



Phishing email — fake Chrome Security Update lure with password-protected malicious ZIP attachment

The user extracted the archive to C:\Users\LetsDefend\Downloads\chrome-updates\ and executed Chrome_updates.exe, giving the trojan its initial foothold on the host.

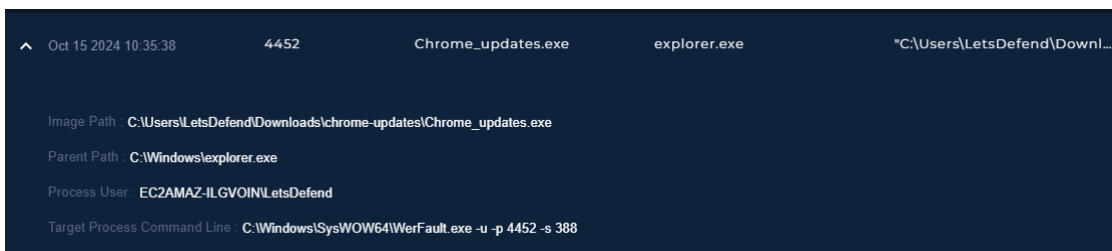


Downloads folder — the extracted chrome-updates directory and the original password-protected archive

4.2 Process & Memory Crash Analysis (WerFault & .dmp)

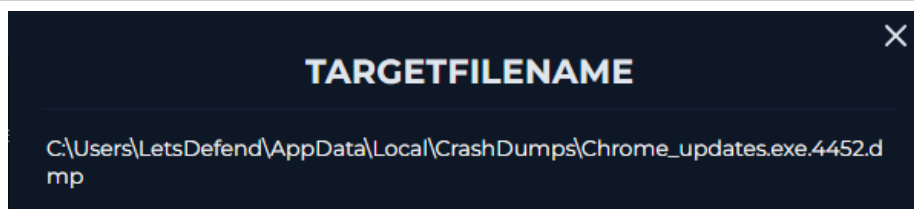
At 10:35:38, Chrome_updates.exe (PID 4452) was observed spawning C:\Windows\SysWOW64\WerFault.exe -u -p 4452 -s 388 — the native Windows Error Reporting process invoked automatically when an application crashes.

```
Time           : Oct 15 2024 10:35:38
Source Process  : Chrome_updates.exe (PID 4452)
Parent Process  : explorer.exe
Image Path      : C:\Users\LetsDefend\Downloads\chrome-updates\Chrome_updates.exe
Target Process  : C:\Windows\SysWOW64\WerFault.exe -u -p 4452 -s 388
```

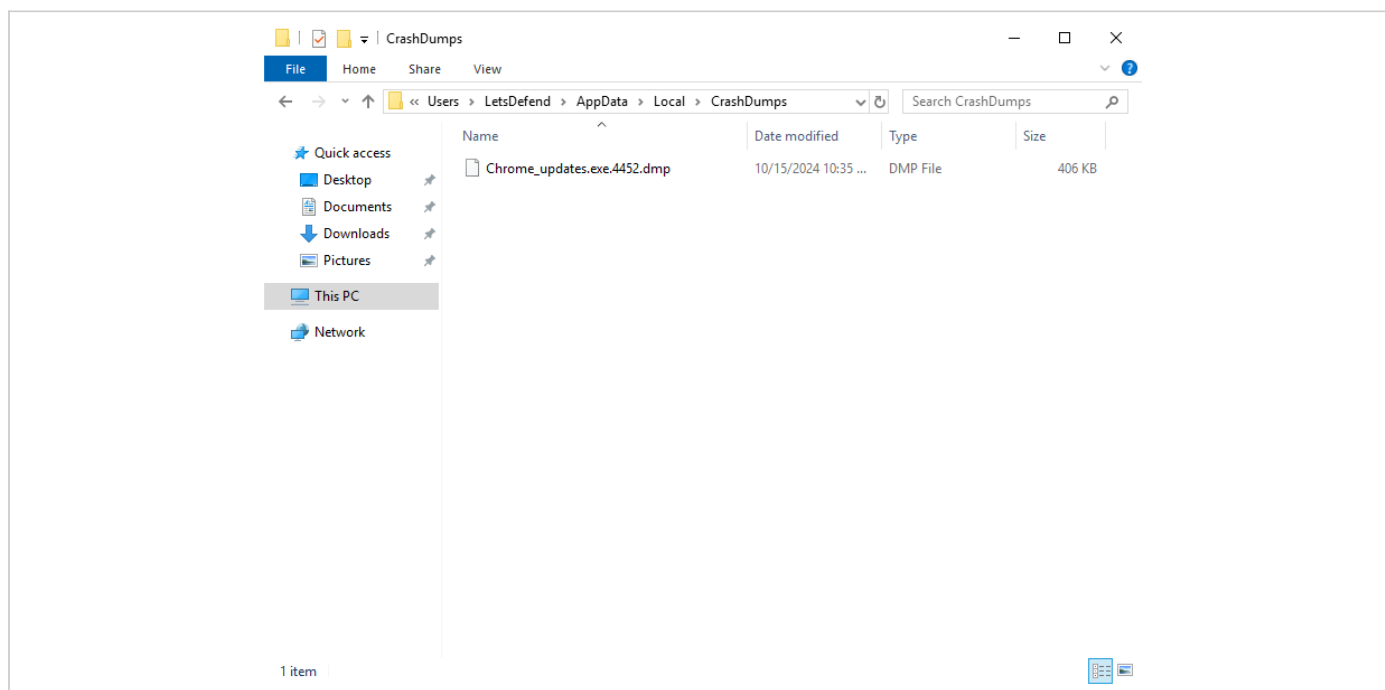


Process log — Chrome_updates.exe (PID 4452) crashing and triggering WerFault.exe

This crash generated a user-mode minidump of the malicious process's memory space, written to the CrashDumps folder — an incidental but highly valuable forensic artifact, since a process memory dump can contain unpacked/in-memory code that is otherwise hidden by the malware's on-disk packing or obfuscation.



TargetFilename — the exact path of the generated crash dump



CrashDumps folder — Chrome_updates.exe.4452.dmp (406 KB), recovered for analysis

The dump file itself was hashed for chain-of-custody and tracking purposes:

```
PS C:\Users\LetsDefend> Get-FileHash -Algorithm SHA256 "C:\Users\LetsDefend\AppData\Local\CrashDumps\Chrome_updates.exe.4452.dmp"
```

```
SHA256: FFC0638D6930FEAEC5ABEF12BCC48B96D1EB45777245ADEED0C72C842ED5766
```

```
Select Windows PowerShell

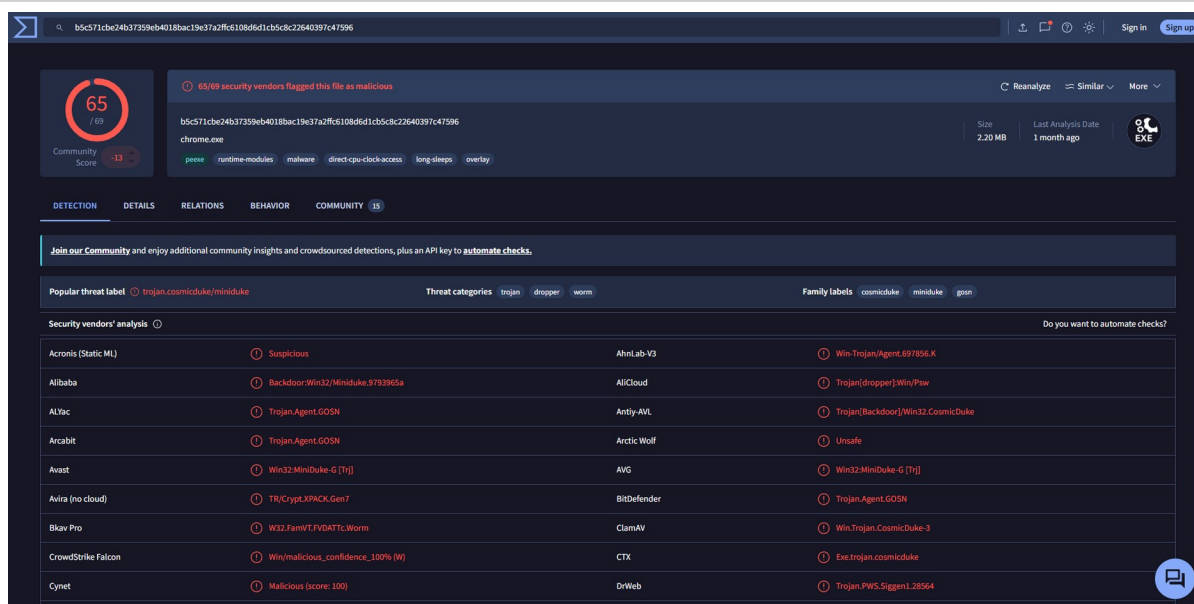
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Users\LetsDefend> Get-FileHash -Algorithm SHA256 'C:\Users\LetsDefend\AppData\Local\CrashDumps\Chrome_updates.exe.4452.dmp'

Algorithm      Hash                                                    Path
-----
SHA256         FFC0638D6930FEAEC5A8EF12BCC48B96D1EB4577245ADEED0C72C842ED5766 C:\Users\LetsDefend\AppData\L...
```

PowerShell — SHA256 hash of the recovered crash dump file

During analysis of the dump contents, an embedded executable resource — internally labeled chrome.exe — was extracted and submitted for reputation analysis. This resource hash returned a strong, independently corroborated malicious verdict:



VirusTotal — 65/69 vendors flag the extracted payload (chrome.exe) as malicious, family: trojan.cosmicduke/miniduke

- Detection rate: 65 out of 69 security vendors flagged the extracted payload as malicious.
- Popular threat label: trojan.cosmicduke/miniduke.
- Family labels: cosmicduke, miniduke, gosn. Categories: trojan, dropper, worm.
- This family is historically associated with APT29 ("Cozy Bear") espionage operations — a significant escalation in the assessed severity and intent of this "fake update" lure.

4.3 Network / C2 Activity Analysis

Log Management and network traffic records for the host were reviewed across the incident window. No successful outbound connection to a known or suspected command-and-control infrastructure was identified, and no data was observed leaving the host. The most likely explanation, corroborated by the crash evidence above, is that the malicious process terminated (crashed) before it could complete its C2 check-in or staging phase.

Critical Analyst Notes

Failed Execution ≠ Clean Host: A crashed process or an unsuccessful C2 connection does not mean the threat was neutralized. The binary was confirmed malicious, matched a known APT-associated family, and executed on the host with user-level privileges before crashing. Dump analysis and intent assessment are mandatory regardless of whether the attack chain completed.

Quarantined vs. Active Threat: Chrome_updates.exe was not automatically quarantined by the endpoint security agent and remained freely accessible on disk from the moment of execution until manual analyst remediation. This window represents real risk — any subsequent execution (by the user, a scheduled task, or persistence mechanism) could have succeeded where the first attempt crashed.

5. Containment, Eradication & Remediation

Actions Taken

- Removed Chrome_updates.exe, the chrome-updates.zip archive, and the associated crash dump from the host (forensic copies retained).
- Isolated the affected endpoint from the network pending full forensic review.
- Checked and confirmed no persistence mechanisms (Run/RunOnce registry keys, Scheduled Tasks, Services) were established before the process crashed.
- Reset credentials for the affected user account as a precaution against any credential exposure during the brief execution window.
- Blocked the sender address (dawid.tomaszewski@resetlocations.com) and associated sender IP (107.154.147.223) at the email security gateway.

Hardening Recommendations

- Block password-protected archive attachments by default at the email gateway, or route them to a sandboxed detonation environment before delivery — this is the exact technique used here to evade content scanning.
- Deploy application allow-listing or attestation controls to prevent unsigned, user-downloaded executables from running without explicit review.
- Ensure endpoint security tooling is configured to auto-quarantine on execution of unsigned binaries from Downloads/Temp paths, not only on signature match.
- Build a detection rule for WerFault.exe spawning shortly (seconds) after execution of a freshly-downloaded, unsigned binary — a useful secondary signal for crashed/failed malware execution.
- Run targeted phishing-awareness training focused on fake software-update lures, a long-standing and highly effective social-engineering pattern.

6. Indicators of Compromise (IOCs)

Type	Value	Context
Sender Email	dawid.tomaszewski@resetlocations.com	Phishing sender
Sender IP	107.154.147.223	Phishing mail source
Malicious Archive	chrome-updates.zip (password: infected)	Email attachment
Malicious Executable	Chrome_updates.exe	Dropped and executed payload
Process ID	4452	PID of the malicious process at execution/crash

Crash Handler Invoked	C:\Windows\SysWOW64\WerFault.exe -u -p 4452 -s 388	Native crash-handling process triggered by payload failure
Forensic Artifact	Chrome_updates.exe.4452.dmp	User-mode crash dump, 406 KB
Dump File Path	C:\Users\LetsDefend\AppData\Local\CrashDumps\Chrome_updates.exe.4452.dmp	Location of the recovered memory dump
Dump SHA256	FFC0638D6930FEAECA5ABEF12BCC48B96D1EB45777245ADEED0C72C842ED5766	Hash of the crash dump file itself
Payload SHA256	b5c571cbe24b37359eb4018bac19e37a2ffc6108d6d1cb5c8c22640397c47596	Hash of the embedded malicious payload (chrome.exe), 65/69 on VirusTotal
Threat Label	trojan.cosmicduke/miniduke (65/69 on VT)	VirusTotal community verdict

7. Lessons Learned & Recommendations

- A crashed payload is not a resolved incident. This case could easily have been dismissed as "malware failed to run, no action needed" — but the extracted payload matched a known APT-associated family. Every execution event deserves a full disposition, regardless of whether it visibly succeeded.
- Memory crash dumps are an underused forensic goldmine. WerFault's default crash-dump behavior incidentally preserved a decoded/in-memory view of the malware that static analysis of the packed on-disk file might not have revealed as clearly.
- Password-protected archives bypassing content inspection remains one of the most reliable phishing delivery techniques in active use — email security policy should treat them as a standing red flag, not a routine delivery method.
- The gap between "not quarantined" and "actively investigated" is where real risk lives. Endpoint tooling that only flags rather than blocks unsigned, freshly-downloaded executables leaves a window attackers can exploit on a retry.
- Attribution-adjacent findings (CosmicDuke/MiniDuke/APT29 indicators) should automatically elevate a case's handling priority and trigger broader environment-wide threat hunting, even when the specific incident appears contained.

— End of Report —